

**TLP:CLEAR**

# MedusaLocker / Bija Industrie — Premium Intelligence Canary

medusalocker-bija-industrie-premium-canary

**NON-PRODUCTION RENDER-QA PREVIEW**

**Generated 2026-08-17T20:18:22.907Z**

**NOT the customer-facing deliverable**

# Table of Contents

1. Executive Summary
2. Scope and Methodology
3. Victim Claim Record
4. Actor Overview: MedusaLocker (RaaS Family)
5. Documented Attack Chain
6. Current Tracked Scale (2026 Snapshot)
7. Historical Indicators (Generic, Not Incident-Specific)
8. Detection
9. Hunting
10. Forecast
11. Alternative Hypotheses
12. Regulatory Considerations
13. Generic Defensive Readiness (GENERIC\_DEFENSIVE\_READINESS)
14. Intelligence Gaps
15. Technical Recommendations
16. Appendix A: Sources & Evidence Ledger

# MedusaLocker / 'Bija Industrie' — Premium Intelligence Canary

**Classification:** TLP:CLEAR — public leak-site claim and open-source actor intelligence

## Executive Summary

---

On 2026-08-16, a group identifying itself as MedusaLocker listed 'Bija Industrie', a France-based manufacturer of specialized aerospace and industrial tooling, on its Tor extortion leak site, claiming 693 emails were extracted. This is a single-source claim; no independent confirmation, victim statement, regulator filing, or data sample has been located. Real, directly-sourced actor context -- drawn primarily from the 2022 CISA/FBI/Treasury/FinCEN joint advisory AA22-181A and independently corroborated in part by Cybersecurity Dive's own reporting on it -- shows MedusaLocker operating as a Ransomware-as-a-Service platform active since at least 2019, with a documented 55-60% affiliate revenue split and a well-characterized RDP/phishing initial-access, PowerShell-propagation, safe-mode-evasion, and shadow-copy-deletion attack chain. ransomware.live's own current tracking shows 83 total MedusaLocker victims across 19 countries, with Bija Industrie its most recently listed. Bija's own site states it serves both civil and military aviation programs; that fact is recorded here for defense-industrial-base relevance only -- no source reviewed describes the content or sensitivity of the claimed 693 emails, and this report does not assert any specific data, military-related or otherwise, was actually exfiltrated.

## Scope and Methodology

---

This report synthesizes five independently retrieved sources, all fetched as raw bytes via direct HTTP fetch with content\_sha256 computed programmatically from the checked-in raw files, never hand-typed: the leak-site tracker ransomware.live (both the Bija-specific victim page and its MedusaLocker group aggregate-statistics page), the victim's own site (bija-industrie.com), the IC3.gov mirror of CISA/FBI/Treasury/FinCEN Joint Cybersecurity Advisory AA22-181A (cisa.gov itself returned HTTP 403 Access Denied on both the advisory page and its own PDF -- documented honestly rather than substituted with paraphrase), and Cybersecurity Dive's independent journalism on that same advisory. Every claim in this report traces to at least one of these five sources via an explicit evidence\_refs/source\_refs chain, visible in the Sources & Evidence Ledger appendix below. No claim in this report is drawn from model memory or generic industry knowledge about ransomware conventions in general. Victim-specific observations (this incident only) are kept structurally and narratively separate from actor-historical context (what is known about MedusaLocker in general) throughout. MITRE ATT&CK tracks an unrelated ransomware operation named 'Medusa' (S1244/G1051) -- a different group from MedusaLocker despite the similar name; that page is never cited here.

## Victim Claim Record

---

Claim posted 2026-08-16 15:20 UTC on MedusaLocker's Tor leak site. Country: France, confirmed via the tracker's own country-flag reference and independently consistent with the victim domain's DNS/WHOIS fingerprint (OVH, a French hosting provider; Mailinblack, a French email-security SaaS). Per the company's own site, Bija Industrie designs and manufactures specialized tooling for the aerospace and industrial sectors, with over 20 years of aerospace experience serving both civil and military aviation programs across three brands. This business-description context is recorded for defense-industrial-base relevance only -- the leak-site claim itself describes only an email count ('693 emails extracted'), with no category, sensitivity, or content description given by any source reviewed, and whether any compromise actually occurred, military-program-related or otherwise, is UNKNOWN on current evidence; this report does not assert it did. Separately, passive DNS/WHOIS fingerprinting confirms the organization's mail infrastructure and a standard SPF configuration -- infrastructure fingerprinting only, not evidence of the initial-access vector.

## Actor Overview: MedusaLocker (RaaS Family)

---

MedusaLocker is a Ransomware-as-a-Service operation that, per a Cybereason report cited by Cybersecurity Dive, first emerged in late 2019 targeting companies across industries, and was particularly active against the healthcare sector during the COVID-19 pandemic. The primary CISA/FBI/Treasury/FinCEN advisory (AA22-181A, published 2022-06-30) documents actors most often gaining initial access through vulnerable RDP configurations, with phishing and spam email campaigns -- directly attaching the ransomware -- as a frequently-used secondary vector. The group operates a RaaS affiliate model in which affiliates typically retain 55-60% of each ransom payment, with the developer retaining the remainder -- a figure independently reported by both the primary advisory and Cybersecurity Dive's own separate coverage of it, the strongest-corroborated actor-context fact in this report.

## Documented Attack Chain

---

The primary advisory documents a specific, repeatable attack chain, quoted directly here. **Execution and propagation (T1059.001):** a batch file runs a PowerShell invoke-ReflectivePEInjection script that edits the EnableLinkedConnections registry value, enabling host/network detection via ICMP and shared-storage detection via SMB. **Defense evasion (T1562.009):** the LanmanWorkstation service is restarted to let the registry edit take effect, known security/accounting/forensic-software processes are killed, and the machine is rebooted into Windows Safe Mode to avoid endpoint defenses. **Impact (T1486):** files are encrypted with AES-256, with the resulting key itself protected by RSA-2048, re-running every 60 seconds. **Persistence:** an executable named svhost.exe or svhostt.exe is copied into %APPDATA%\Roaming with a scheduled task re-running it every 15 minutes. **Recovery inhibition (T1490):** local backups are deleted, startup recovery options disabled, and volume shadow copies removed. All of this is documented actor CAPABILITY -- no TTP specific to the Bija Industrie incident has been observed by any source reviewed.

## Current Tracked Scale (2026 Snapshot)

---

ransomware.live's own current aggregate tracking shows 83 total MedusaLocker victims listed since its earliest tracked victim (estimated attack date 2021-11-03), spanning 19 countries, with an average 83.1-day delay between estimated attack date and leak-site claim. 37.0% of tracked victims show a domain-level overlap with known infostealer-malware logs -- suggestive, in aggregate, of a credential-theft-adjacent access pathway across the tracked population, though this is not evidence of any specific victim's initial-access vector, including Bija Industrie's. At the time of this report, Bija Industrie is the group's own most recently listed victim.

## Historical Indicators (Generic, Not Incident-Specific)

---

The primary advisory publishes generic MedusaLocker indicators dated 2019-2022 -- encrypted-file extensions, ransom-note filenames (e.g. `how_to_recover_data.html`, `READINSTRUCTION.html`), Bitcoin wallets, email addresses, and Tor addresses -- with the advisory's own explicit caution that historical IP indicators are 'several years old' and should be vetted before any blocking action. None of these specific artifacts is claimed by any source reviewed to have been observed at Bija Industrie; this report contains no incident-specific IOC.

## Detection

---

A Sigma detection concept is provided at SYNTAX\_VALIDATED maturity only -- neither lab testing nor any deployment validation has been performed this session -- targeting two of MedusaLocker's own documented, quotable indicators: svhost.exe/svhostt.exe persistence in %APPDATA%\Roaming, and the invoke-ReflectivePEInjection/EnableLinkedConnections registry-propagation pattern. A match does not by itself confirm MedusaLocker attribution (see the rule's own falsepositives field, including the common 'svhost' masquerade risk). Full rule body:

YAML

```
title: MedusaLocker svhost/svhostt Persistence and EnableLinkedConnections Registry Propagation
id: reportx-canary-medusalocker-svhost-persistence
status: experimental
description: >
  Detects two command-line/registry indicators documented by CISA/FBI/
  Treasury/FinCEN advisory AA22-181A for the MedusaLocker ransomware
  family: persistence via an executable named svhost.exe or svhostt.exe
  copied into %APPDATA%\Roaming with a 15-minute recurring scheduled
  task, and the invoke-ReflectivePEInjection PowerShell script's edit of
  the EnableLinkedConnections registry value used for network
  propagation. Either indicator alone is a strong ransomware
  precursor/impact-stage signal; this rule does not by itself confirm
  MedusaLocker attribution for any specific incident.
references:
  - https://www.ic3.gov/CSA/2022/220630.pdf
  - https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-181a
logsource:
  category: process_creation
  product: windows
detection:
  selection_svhost_persistence:
    Image|endswith:
      - '\svhost.exe'
      - '\svhostt.exe'
    CommandLine|contains: 'AppData\Roaming'
  selection_registry_propagation:
    CommandLine|contains|all:
      - 'invoke-ReflectivePEInjection'
      - 'EnableLinkedConnections'
  condition: selection_svhost_persistence or selection_registry_propagation
falsepositives:
  - Legitimate 'svhost' naming is a common OS-process masquerade target; verify full path and hash
    before response
  - Legitimate administrative scripts that modify EnableLinkedConnections for UAC-related remote
    administration purposes
level: high
```

## Hunting

---

Given the documented, specific persistence naming convention, a defensible hunting hypothesis is to search endpoint process-creation and scheduled-task telemetry for svhost.exe or svhostt.exe executing from %APPDATA%\Roaming rather than a genuine Windows system path, and for any scheduled task with a roughly 15-minute recurrence tied to such a binary. Separately, given the advisory's documentation of RDP as MedusaLocker's dominant initial-access vector, hunting teams should prioritize reviewing external-facing RDP authentication logs for brute-force patterns ahead of reviewing email-gateway telemetry for spearphishing delivery -- while still covering both, since the advisory documents phishing as a real, if secondary, vector. This report does not include incident-specific IOCs for Bija Industrie -- none were located by any source reviewed.

## Forecast

---

MEDIUM confidence that MedusaLocker-branded activity will continue at or above its documented multi-year pace (83 tracked victims across 19 countries) over the next 90 days, continuing to rely predominantly on RDP exposure and phishing/spam as initial-access vectors -- tempered by the inherent unpredictability of law-enforcement disruption events and by this report's actor-context sources being predominantly a single 2022 advisory refreshed only by current tracker counts, not a fresh 2026 technical reassessment. See the structured forecast record (supporting observations, assumptions, alternative scenarios, and indicators to watch) in this bundle's **forecasts** field.

## Alternative Hypotheses

---

Two genuinely open analytic questions are weighed explicitly rather than resolved by assumption. **First**, whether the leak-site listing reflects a genuine, currently-undisclosed compromise (**H1**, consistent with MedusaLocker's persistent multi-year operating cadence and the real infrastructure fingerprinting captured for this domain) versus an unconfirmed or overstated claim (**H2**, consistent with the total absence of a proof sample, independent confirmation, or victim acknowledgement). **Second**, if a compromise did occur, which of MedusaLocker's two documented initial-access vectors -- RDP (**H1**, the advisory's own 'most often' vector) or phishing/spam (**H2**, its documented 'frequently' secondary vector) -- hunting and forensic review should prioritize first, given that no incident-specific initial-access evidence exists for this victim either way.

## Regulatory Considerations

---

GDPR (EU) / France (CNIL) is assessed NOT\_ASSESSED: whether the claimed 693 emails include personal data of identifiable individuals is not established by any source reviewed, and whether any compromise occurred at all remains UNKNOWN. The NIS2 Directive (EU) is assessed NOT\_ASSESSED: Bija Industrie's specific sector/entity-size classification against NIS2's essential/important-entity thresholds is not established by any source reviewed. HIPAA is assessed NOT\_APPLICABLE: Bija Industrie is a France-based manufacturer with no established US healthcare nexus. PCI-DSS is assessed NOT\_ASSESSED: no source reviewed describes the organization's payment-processing footprint.

## Generic Defensive Readiness (GENERIC\_DEFENSIVE\_READINESS)

---

Standard ransomware readiness guidance -- a segmented offline backup and recovery plan, RDP hardening and MFA, network segmentation, behavioral detection for mass encryption and unexpected Safe Mode reboots, shadow-copy/backup-tampering monitoring, and a tested IR plan with a defined leak-site-monitoring process -- is provided as general hardening grounded in MedusaLocker's own documented attack chain and the advisory's own mitigations list, not as evidence any specific technique was used against this victim.

## Intelligence Gaps

---

Seven gaps are explicitly unresolved by any source reviewed for this report: victim acknowledgement is unavailable; no incident-specific IOCs were observed; no proof sample of the claimed extracted emails exists; no independent confirmation of the leak-site claim was located; no initial-access or incident-specific TTP evidence was found; whether any of MedusaLocker's documented general TTPs were used in this specific incident is unestablished; whether the claimed 693 emails include personal data or defense-industrial-base-sensitive content is unestablished; and which specific MedusaLocker affiliate is responsible for this claim is unestablished.

## Technical Recommendations

---

1. Disable or restrict internet-facing RDP and enforce MFA on all remote-access accounts -- the direct countermeasure to MedusaLocker's documented primary initial-access vector (evidence: c-medusalocker-initial-access).
2. Maintain a segmented, offline, tested backup and recovery plan, and monitor for shadow-copy deletion and backup-service tampering -- the direct countermeasure to MedusaLocker's documented recovery-inhibition behavior (evidence: c-medusalocker-recovery-inhibition).
3. Deploy monitoring for MedusaLocker's specific documented persistence pattern (svhost.exe/svhostt.exe in %APPDATA%\Roaming with a 15-minute scheduled task) via the detection rule above (evidence: c-medusalocker-persistence).
4. Train users to recognize and report phishing/spam attempts -- the direct countermeasure to MedusaLocker's documented secondary initial-access vector (evidence: c-medusalocker-initial-access).

## Appendix A: Sources & Evidence Ledger

---

Every source registered in this report's evidence graph, its retrieval/integrity metadata, and every captured excerpt tied to it -- the complete evidentiary basis for every claim above.

### s-ransomwarelive-bija — ransomware.live (leak-site tracker)

- URL: <https://www.ransomware.live/id/QmlqYSBJbmR1c3RyaWVAbWVkdXNhbg9ja2Vy>
- Type: LEAK\_SITE\_AGGREGATOR
- Reliability: MODERATE
- Retrieved: 2026-08-17T00:00:00Z
- content\_sha256: b37b7e1766140aa30654eaff721ec4b8cab1051bead83ea2f87606a894f64880

Bija Industrie bija-industrie.com Group Medusalocker Discovered 2026-08-16 15:20 UTC Est. attack date 2026-08-16 ...  
Description: Organization with 693 emails extracted. Domain: bija-industrie.com.

WHOIS Emails [abuse@ovh.net](mailto:abuse@ovh.net). MX Records mx-mibc-fr-08.mailinblack.com. mx2.mail.ovh.net. mx3.mail.ovh.net. TXT Records v=spf1 include:mx.ovh.com ~all. Cloud / SaaS Services Detected: Mailinblack. Country flag reference: flags/FR.svg.

### s-bija-own-site — BIJA Industrie (the company's own site)

- URL: <https://bija-industrie.com>
- Type: VICTIM\_STATEMENT
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content\_sha256: 505c5e0e427ad0718f14de91638e2d84ee14189ec2dbd34673651c53cb122628

'conception, la fabrication et la distribution d'outils et d'outillages spécifiques pour les secteurs aeronautiques et industriels' (design, manufacturing, and distribution of specialized tools for aerospace and industrial sectors); 20+ years of aerospace experience; serves civil and military aviation programs; three brands (BIJA Industrie, MMI, MRO Integral Solutions).

### s-ic3-medusalocker-advisory — FBI / CISA / Dept. of the Treasury / FinCEN (Joint Cybersecurity Advisory AA22-181A, via the ic3.gov mirror -- cisa.gov itself returned HTTP 403 Access Denied on both the HTML advisory and its own PDF, consistent with the blocking behavior documented elsewhere in this canary set)

- URL: <https://www.ic3.gov/CSA/2022/220630.pdf>
- Type: PRIMARY\_TECHNICAL\_ADVISORY
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content\_sha256: 049a1e4e586e28b8c6619625014fe3aaff946b492a5a780c952ed4ab41df8760

MedusaLocker ransomware actors most often gain access to victim devices through vulnerable Remote Desktop Protocol (RDP) configurations [T1133]. Actors also frequently use email phishing and spam email campaigns -- directly attaching the ransomware to the email -- as initial intrusion vectors [T1566].

MedusaLocker ransomware uses a batch file to execute PowerShell script `invoke-ReflectivePEInjection` [T1059.001]. This script propagates MedusaLocker throughout the network by editing the `EnableLinkedConnections` value within the infected machine's registry, which then allows the infected machine to detect attached hosts and networks via ICMP and to detect shared storage via SMB Protocol.

Restarts the `LanmanWorkstation` service, which allows registry edits to take effect. Kills the processes of well-known security, accounting, and forensic software. Restarts the machine in safe mode to avoid detection by security software [T1562.009].

Encrypts victim files with the AES-256 encryption algorithm; the resulting key is then encrypted with an RSA-2048 public key [T1486]. Runs every 60 seconds, encrypting all files except those critical to the functionality of the victim's machine and those that have the designated encrypted file extension.

Establishes persistence by copying an executable (`svhost.exe` or `svhostt.exe`) to the `%APPDATA%\Roaming` directory and scheduling a task to run the ransomware every 15 minutes.

Attempts to prevent standard recovery techniques by deleting local backups, disabling startup recovery options, and deleting shadow copies [T1490].

MedusaLocker appears to operate as a Ransomware-as-a-Service (RaaS) model based on the observed split of ransom payments ... consistently split between the affiliate, who receives 55 to 60 percent of the ransom, and the developer, who receives the remainder.

Disclaimer: Many of these observed IP addresses are several years old and have been historically linked to MedusaLocker ransomware. We recommend these IP addresses be investigated or vetted by organizations prior to taking action, such as blocking. Ransom note file names observed include `how_to_recover_data.html`, `instructions.html`, `READINSTRUCTION.html`, and `recovery_instructions.html`, placed into every folder containing an encrypted file.

Implement a recovery plan that maintains and retains multiple copies of sensitive or proprietary data ... in a physically separate, segmented, and secure location. Implement network segmentation and maintain offline backups of data. Install, regularly update, and enable real-time detection for antivirus software on all hosts. Install updates for operating systems, software, and firmware as soon as possible. Audit user accounts with administrative privileges and configure access controls according to the principle of least privilege.

## s-ransomwarelive-medusalocker-group — ransomware.live (leak-site tracker, group aggregate page)

- URL: <https://www.ransomware.live/group/medusalocker>
- Type: LEAK\_SITE\_AGGREGATOR
- Reliability: MODERATE
- Retrieved: 2026-08-17T00:00:00Z
- content\_sha256: 4f5340469772b14920a045a4cec08855d2704b81d15bb5c4b294dc080b485ac2

Victims 83. First Victim (est. attack date) 2021-11-03. Discovery Date 2022-11-15. Last Seen 2026-08-16. Avg Delay 83.1 days. Infostealer 37.0% victims with domain. Countries 19 hit.

## s-cybersecuritydive-medusalocker — Cybersecurity Dive

- URL: <https://www.cybersecuritydive.com/news/fbi-cisa-medusalocker-ransomware/626483/>
- Type: JOURNALISM
- Reliability: MODERATE
- Retrieved: 2026-08-17T00:00:00Z
- content\_sha256: d9ca6aa5f4c80f3c912a53b22aa4c1f31999a6c1f3558c71b34b40f03a937edc

MedusaLocker operates under the ransomware as a service model, splitting payments with affiliates who typically get 55% to 60% of the proceeds.

A report from Cybereason said the MedusaLocker first emerged in late 2019, targeting companies across industries.

The group was particularly active in the healthcare space, where many organizations were attacked in connection to the COVID-19 pandemic.